05 · Risk Management Plan (Risk Register and RAID log): writing guide

Owner suggestion: Member 2. **Length:** 3 to 4 pages. **Time:** 35 to 45 minutes, mostly by updating your Term 1/2 risk register.

Purpose

Show how you **identified, rated, responded to and tracked** risks across the project, and record the Assumptions, Issues and Dependencies in a RAID log. The brief asks for "Risk Management Plan (Risk Register & RAID Log)". You already started a risk register in Term 1 and updated it in Term 2, so this is the **final** version, including what actually happened.

Key ideas explained simply

- **Risk:** something that *might* happen and would affect the project (good or bad). Write it as **cause, event, effect**: "Because X, Y might happen, resulting in Z".
- **Issue:** a risk that has *already happened* (a problem you must fix now).
- **Assumption:** something you believe is true but have not proven.
- **Dependency:** something outside your control that you rely on.
- **RAID:** Risks, Assumptions, Issues, Dependencies in one log.
- **Probability and impact:** score each 1 to 5. **Score = probability × impact.** For example 1 to 6 Low, 7 to 14 Medium, 15 to 25 High (choose your own thresholds and state them).
- **Responses:** *Avoid* (remove the cause), *Mitigate* (reduce probability or impact), *Transfer* (shift to someone else, for example a provider), *Accept* (do nothing now, monitor), and for good risks *Exploit/Enhance/Share*.

Part 1: Risk Management Plan (about 1 page, your words)

Answer each in 2 to 4 sentences:

1. **Approach:** how you identify risks (brainstorm, sprint reviews, testing).
2. **Roles:** who owns the register and who reviews it.
3. **Frequency:** when it is reviewed (the brief says maintain it at each phase and review at bi-weekly sprint reviews).
4. **Scoring:** the 1 to 5 scales and the High/Medium/Low thresholds. Add a small probability-impact grid.
5. **Escalation:** what you do when a risk becomes High or turns into an issue.

Score band	Rating	Action
15-25	High	Act now, report to the lecturer/team lead
7-14	Medium	Mitigation plan, review each sprint
1-6	Low	Monitor

Part 2: Risk Register

ID	Risk (cause, event, effect)	Category	Prob. (1-5)	Impact (1-5)	Score	Response	Action	Owner	Status
R1	*Example:* Because email addresses are not verified, someone may register using another student's CPUT address, damaging trust	Security				Mitigate	Domain rule, reports, suspension; add email verification		Open
R2									

(The example is only for format; rate and own it yourself.)

Risk ideas that really apply to CPUTrade *(pick those relevant, rate them yourselves, add your own from Term 1/2)*

Technical and security

- Fake accounts using someone else's CPUT email (no email verification yet).
- Fraudulent sellers or fake listings (moderation depends on users reporting).
- Password guessing attacks (rate limiting added).
- Development secrets leaking or being used in production (production check added).
- Concurrency bugs corrupting stock (found in testing and fixed).
- Data loss: photos stored on local disk, no automated backups.
- Dependence on one database and one server; no cloud hosting.
- Uploaded files that are not real images (header check added).

Scope, schedule and team

- Scope creep or mismatch with the brief (payments, microservices, AI fraud detection).
- Deadline pressure; documents and demo left to the last days.
- Uneven workload or a team member unavailable (team of three instead of five).
- Learning curve for the technologies.

- Merge conflicts or lost work in Git.

Adoption and business

- Low adoption because students prefer WhatsApp and Facebook.
- Vendors not interested or hard to verify.
- Privacy and data protection obligations (POPIA): no privacy policy, no account deletion yet.
- Safety of in-person meet-ups.

Demo and delivery

- Demo failing on the day (laptop, database, internet).
- Video exceeding the time limit.

Part 3: RAID log

ID	Type (R / A / I / D)	Description	Impact	Owner	Date raised	Status and resolution
I1	Issue	*Example:* Simultaneous "mark sold" requests reduced stock by only one	Wrong stock counts			Fixed with a database lock; retested (50 to 44)
A1	Assumption	*Example:* Students own their CPUT mailbox	Fake accounts if untrue			Open
D1	Dependency	*Example:* Free-licence photos and credits	Demo images			Closed

Real events you can log as Issues (from this project's testing):

- Concurrent sale bug: fixed and retested.
- The first locking approach failed on MariaDB (the XAMPP database rejected the syntax) and was replaced with a standard `SELECT ... FOR UPDATE`.
- The database held old test data that showed up during demo testing; replaced with a clean demo dataset (the old data was backed up).

Assumptions to log: students use their own CPUT email; users agree to meet and pay in person; users have a modern phone browser with push support. **Dependencies to log:** database server availability; browser support for installable apps and push notifications; free tools and photos; (future) email provider, payment gateway, hosting.

Part 4: Closing paragraph (your words)

Which risks actually occurred? Which responses worked? What risk did you underestimate? What would you do differently? (This links to your Reflection.)

Common mistakes

- A list of risks with no scores, owners or responses.

- Risks written as vague words ("bugs"). Write cause, event, effect.
- Never updating the register from Term 1 (markers can compare).
- Not showing what really happened to the risks (status and outcome).

Checklist

- [ ] Plan section: approach, roles, frequency, scale, escalation
- [ ] At least 10 to 12 risks, each with score, response, action, owner, status
- [ ] RAID log with all four types and real entries
- [ ] Updated from Term 1/2 and shows outcomes
- [ ] Owners are your three members